



ISC 互联网安全大会



360 互联网安全中心



云计算安全国际标准发展现状及相关思考

谢玮 中国信息通信研究院安全研究所副所长

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原“中国互联网安全大会”)

目录

① 云计算安全形势

- 云计算发展步伐持续加快
- 云安全新老问题不断交织
- 云安全标准化工作得到广泛重视

② 云计算安全标准化工作概述

③ ITU-T云计算安全标准现状

④ 相关思考

云计算安全形势：云计算发展步伐持续加快



ISC 互联网安全大会



360 互联网安全中心

近年来，云计算市场增长迅速，行业应用不断深化，各大云服务商不断加快云计算基础设施的建设布局。与此同时，云计算关键技术的快速迭代更新推动着云技术架构和应用模式不断演进。

◆ 全球云计算市场规模稳定增长

- 2017年，以IaaS、PaaS、SaaS为代表的主要公有云服务市场规模达**1110亿美元**（约合人民币7635.9亿元）；
- 预计到2021年，全球公有云市场规模将达2461亿美元，年复合增长率达**18.89%**。



信通院《云计算发展白皮书（2018年）》，整理自Gartner

◆ 云计算底层技术架构不断演变

- 关键技术快速迭代：**容器、高性能计算、微服务架构等技术发展加快云计算技术架构迭代更新；
- 技术融合驱动业务应用不断深化：**云网融合，云计算与物联网、工业互联网、人工智能等有机结合不断深化业务应用。

◆ 多云形态逐渐成为主流应用模式

- 企业需要多种云环境并存以适应业务发展趋势；
- 从基础架构为核心到**应用为核心**的转变；
- 结合公有云的弹性和私有云的私密性，寻求**最佳性能和安全可靠间的平衡**。

云计算安全形势：新老安全问题不断交织

一方面，网络病毒、漏洞入侵、内部泄漏等传统网络安全威胁依然存在；另一方面，云环境网络规模化、数据信息海量化、存储服务集约化等特点也给云平台架构和云业务发展带来新的安全挑战。

◆ 云安全事件频发，网络安全问题持续发生

- 2016年9月，国际CDN厂商Cloudflare曝出**API密钥安全漏洞**，导致数百万网络托管客户数据被泄露；
- 2017年3月，微软Azure公有云存储故障导致业务受影响**超过8小时**；
- 2017年6月，亚马逊AWS共和党数据库中的美国**2亿选民个人信息被曝光**。



◆ 专业化、集约化的新计算模式引发新安全风险

承载多类型业务应用，服务模式复杂化引发**业务逻辑安全、认证鉴权和不良信息管控**等安全问题



多使用第三方组件等开源软件系统性安全功能相对缺乏，存在**安全漏洞**



存储、计算等多层面资源虚拟化，带来**数据管理权与所有权分离，网络边界模糊**等问题



各类数据集中存储，涉及海量用户敏感信息和数据资产，安全问题将引发**“一点突破、全网皆失”**的严重后果



◆ 云计算安全标准化工作重要性

- 云基础设施作为承载各类应用的**底层关键信息基础设施**，其安全性与其上各类关键业务系统、基础资源、用户数据安全性强相关，成为影响云计算发展的关键因素之一；
- 缺乏统一的**概念术语、架构、测评、风险管理**等标准，将对技术的发展应用和产业化形成阻碍。

国际标准化组织

- **国际标准化组织、开源组织、区域化标准机构**相继开展云计算安全标准化工作；
- ISO IEC JTC1 SC27（信息安全分技术委员会）最早于2010年开始推进云计算安全标准化工作；
- ITU-T于2010年成立云计算焦点组，并于2011年10月，重组成立SG17 Q8云计算安全研究组，持续推进云计算安全标准化工作。

我国标准化组织

- 我国主要在**国家标准和行业标准**两个层面开展云计算安全标准化工作；
- TC260于2011年9月发布《云计算安全及标准研究报告》，开展云计算安全相关标准工作，目前《云计算服务安全指南》等**4项相关标准已发布**，另有4项标准已到报批稿阶段；
- CCSA TC8 WG4于2011年成立**云计算安全子工作组**，组织制定了多项云计算安全方面的标准和研究报告。

目录

- ① 云计算形势
- ② 云计算安全标准化工作概述
 - 国际云计算安全标准工作
 - 我国云计算安全标准工作
- ③ ITU-T云计算安全标准现状
- ④ 相关思考

云计算安全标准化工作概述：国际



ISC 互联网安全大会



360 互联网安全中心

国际标准化组织较早认识到云计算安全标准化工作对发展的重要性，从顶层设计、安全架构、云计算场景等方面，自上而下、全方面、体系化开展云计算安全标准研制工作。

国际标准化机构从整体架构到细分领域全面推动标准工作



ISO/IEC: 《开放虚拟机格式》
《云计算安全与隐私管理系统》
《公共云计算服务的控制措施实用规则》等系列标准

ITU-T: 《云计算的安全框架》
《软件即服务应用环境的安全要求》
《云计算监控服务的安全要求》
《云服务客户数据安全导则》
《云计算的安全框架》

开源组织和联盟注重开源安全技术架构、应用场景中的安全问题



开放式组织联盟 (TheOpenGroup): 《云安全和SOA参考架构》等

云安全联盟 (CSA): 《云计算面临的严重威胁》
《关键领域的云计算安全指南》等

结构化信息标准促进组织 (OASIS): 《身份在云中的使用》

分布式管理任务组 (DMTF): 《云管理体系结构》

区域标准化组织受云计算发展和监管需求影响开展安全标准探索



NIST: 《云计算参考体系架构》
《完全虚拟化技术安全指南》等

区域标准组织 (美国) CIO委员会: 《美国政府云计算风险评估方法》

欧洲网络与信息安全管理局 (ENISA): 《云计算——信息安全保障框架》
《政府云的安全和弹性》等

云计算安全标准化工作概述：我国



我国在2011年开始云计算安全相关标准制定工作，侧重于云计算应用场景的安全规范，国家标准和行业标准同步推进。

◆ TC260聚焦云计算安全应用和服务等方面，制定和发布了相关国家标准

- **基础标准：**《信息安全技术 云计算服务安全指南》等；
- **产品和应用规范：**《信息安全技术 网站安全云防护平台技术要求》《信息安全技术 政府门户网站云计算服务安全指南》《信息安全技术 桌面云安全技术要求》等；
- **面向政务云等对象的云计算安全服务指导：**《信息安全技术 云计算服务安全能力要求》《信息安全技术 云计算服务运行监管框架》等。

◆ CCSA在云计算安全总体架构、隐私和数据保护等方面持续推进行业相关标准工作

- **总体架构和管理要求：**《云计算安全架构》《公有云服务安全防护要求》等；
- **安全要求和应用：**《云计算身份识别与访问管理应用场景及技术要求》等；
- **面向行业云等对象的云计算安全服务指导：**《基于云计算的居民健康服务平台安全框架》《基于云计算的互联网数据中心信息安全技术要求》等。

我国除加快制定国内云计算安全标准外，积极参与国际标准的制定，
主导ITU-T云计算安全相关标准制定工作

目录

- ❶ 云计算形势
- ❷ 云计算安全标准化工作概述
- ❸ ITU-T云计算安全标准现状
 - 概述
 - 标准架构
 - 总体要求
 - 安全设计
 - 安全实现、最佳实践和指南
- ❹ 相关思考

ITU-T云计算安全标准现状：概述



ISC 互联网安全大会



360 互联网安全中心

多年来我国企业和研究机构等广泛参与到ITU-T SG17 Q8云计算安全标准制定工作中，承担工作组报告人、编辑人工作，发布X.1601、X.1631等相关标准，主导推进ITU-T云计算安全标准制定。

◆ ITU-T SG17 Q8：云计算安全工作组

- 中国信息通信研究院安全所担任ITU-T SG17 Q8工作组报告人，**促进我国发挥主导作用**；
- 制定相关标准或其他文档，**促进云计算的安全性**；
- 制定标准，**明确安全要求和威胁，保障云计算服务安全**；
- 制定**身份认证机制、审计技术、风险评估**等云计算生态系统相关标准；

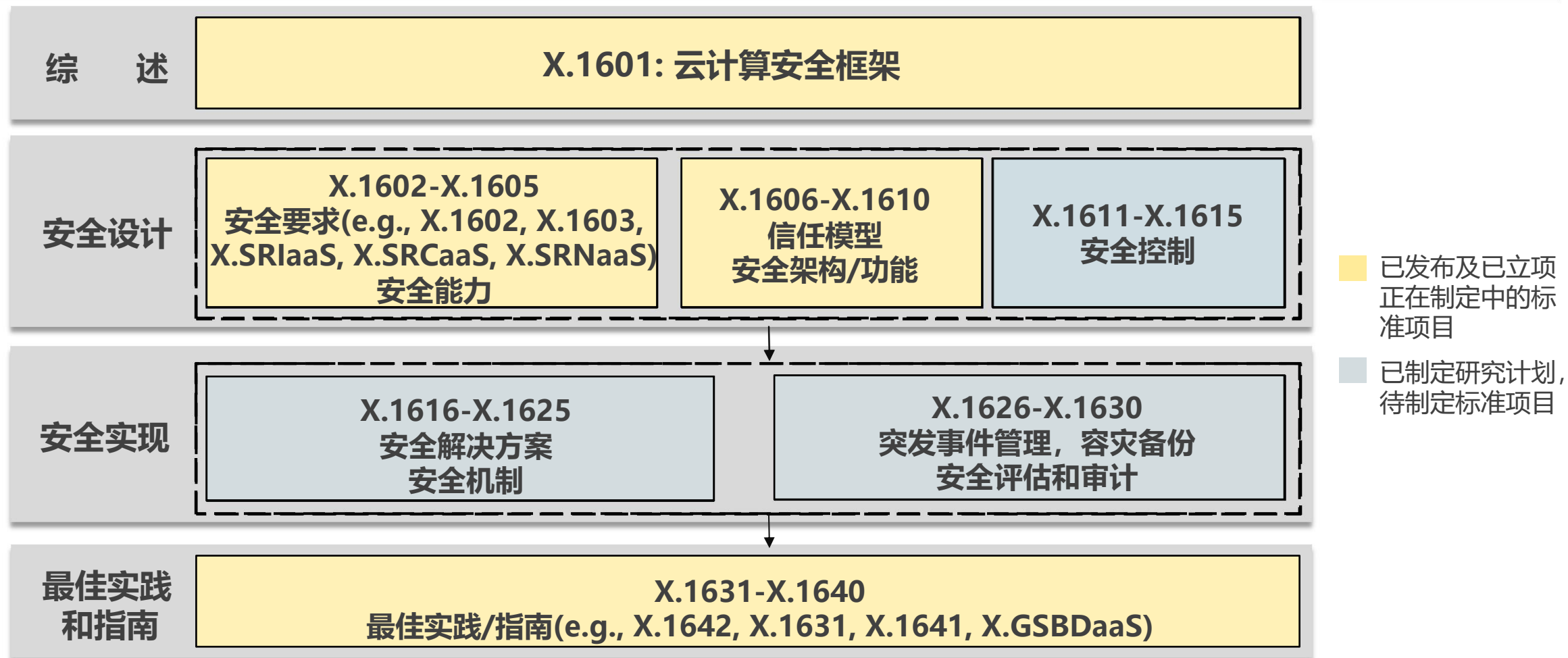


.....



ITU-T相关云计算安全标准：标准架构

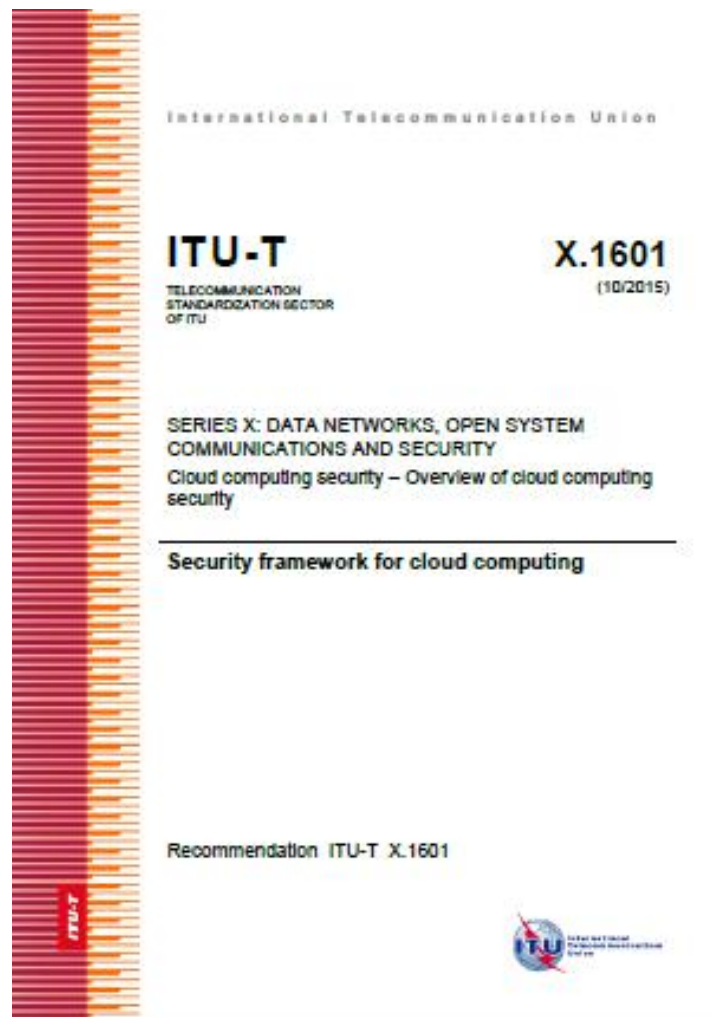
ITU-T最早于2010年开始云计算安全相关标准化工作，从综述、安全设计、安全实现、最佳实践和指南等方面，构建云安全标准架构。



ITU-T相关云计算安全标准：总体要求

◆ X.1601：首个正式发布的云计算安全ITU-T国际标准

- **基础框架标准**，指导云计算安全具体标准的制定，指导云服务商设计和部署云安全解决方案，指导云服务用户考察云服务商的安全能力；
- **明确提出对云计算威胁和挑战**，并从云服务用户（CSC）、云服务提供商（CSP）和第三方云服务伙伴（CSN）三个角色进行了分析；
- **明确应对云计算安全威胁和挑战的云服务安全能力标准**；
- **提出创新性的云计算安全框架方法**，明确从威胁分析到安全能力再到安全框架的三步骤分析法。



ITU-T相关云计算安全标准：安全设计

目前已发布的ITU-T云计算安全设计相关标准有X.1602、X.1603，主要是对云服务提供商和云服务合作伙伴提出SaaS应用环境安全要求，以及对云服务提供商和云服务客户提出全周期安全监控的要求。

◆ X.1602：软件即服务（SaaS）应用环境的安全要求

- 针对云服务提供商（CSP）和云服务合作伙伴（CSN），提出基于SaaS应用成熟度级别的SaaS应用环境安全要求。

◆ X.1603：云计算监控服务的安全要求

- 针对云计算环境下监控服务，分析数据安全威胁和挑战，描述监控服务的数据范围、数据生命周期、数据获取和数据存储等数据安全要求。

◆ X.SRIaaS、X.SRCaaS等相关标准正加快制定

- X.SRIaaS、X.SRCaaS、X.SRNaaS**等安全要求相关标准工作已立项，在基础设施即服务、网络即服务等业务方面，持续推进安全标准化研制工作。



ITU-T相关云计算安全标准：安全实现、最佳实践和指南（1）

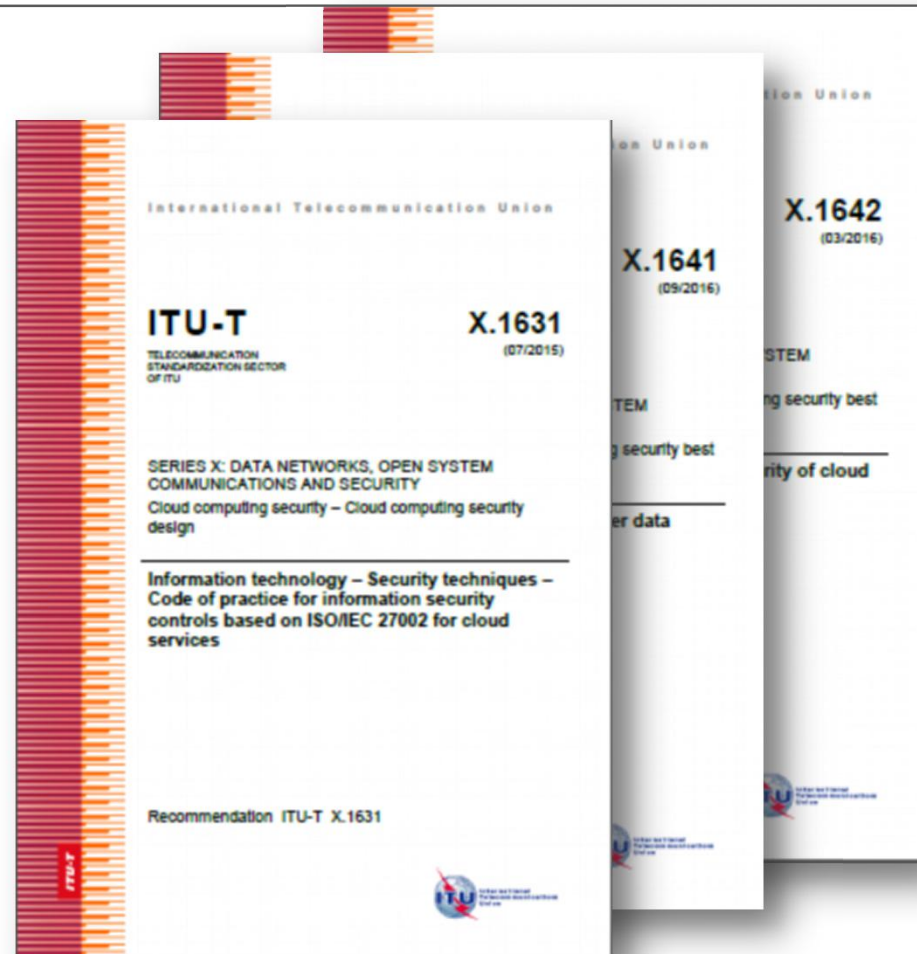
除X.1631明确云计算最佳实践和指南总体架构外，X.1641、X.1642也在数据安全、操作安全方面，对缓解云计算的安全风险及其操作面临的安全挑战，以及对保障数据生命周期各阶段的安全起指导作用。

◆ X.1631|ISO/IEC 27017：为云业务提供商和云服务客户提供安全控制指导

- X.1631是ITU-T和ISO/IEC通用标准；
- 在ISO/IEC 27002 《信息安全管理实用规则》的基础上：
 - 完善了基于ISO/IEC 27002系列标准中规定的**控制实施指导**；
 - **新增对云服务有关的活动安全控制事件指导。**

◆ X.1641：云服务客户数据安全导则

- 针对云服务客户（CSC），分析了CSC数据安全性的生命周期，以及对保障数据生命周期的各阶段提出安全要求。



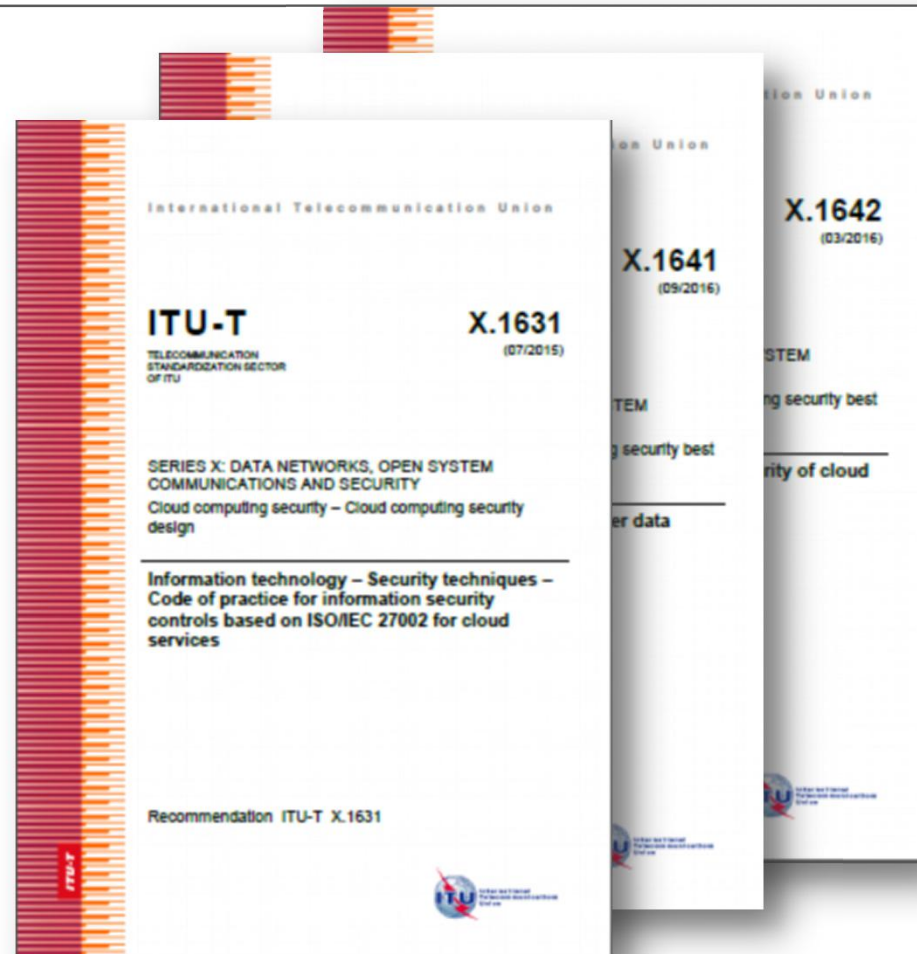
除X.1631明确云计算最佳实践和指南总体架构外，X.1641、X.1642也在数据安全、操作安全方面，对缓解云计算的安全风险及其操作面临的安全挑战，以及对保数据生命周期各阶段的安全起到指导作用。

◆ X.1642：云计算的运营安全导则

- 针对云业务提供商（CSP），分析云计算操作的安全要求和标准，为日常维护提供了一系列安全措施并详细阐述安全工作。

◆ X.GSBDaaS等相关标准正加快制定

- **X.GSBDaaS**安全最佳实践和指南相关标准工作已立项，研究制定工作正加快推进。
- 此外，安全机制、容灾备份、安全评估和审计、安全能力、信任模型、安全架构/功能等相关标准制定工作正同步推进。



目录

- ① 云计算形势
- ② 云计算安全标准化工作概述
- ③ ITU云计算安全标准现状
- ④ 相关思考
 - 完善标准规划和体系建设
 - 加强安全监管力度

云计算专业化、规模化的新计算模式，给云计算业务带来了新的安全挑战，安全问题成为影响云计算发展的关键。未来，为了更好地应对云计算发展的新老安全问题，我国应坚持鼓励支持和规范发展并行，从推进安全标准、健全安全机制等方面，不断推动云计算技术的安全发展和应用。

◆ 结合云计算技术发展，进一步强化云计算安全标准的动态完善和落地实施

1

- 跟踪云计算技术和标准化发展动态，完善技术标准体系，加快对**云计算安全机制、安全评估和审计、安全最佳实践**等新标准的立项和研制工作。

2

- 对云网融合等云计算技术架构新模式，公有云、私有云、混合云等多种云并存的云服务环境，强化跟踪和研究，**云计算安全同步更新迭代。**

3

- 鼓励政产学研各界积极参与到国际标准制定工作中，推动我国云计算安全等标准国际化，逐步**提升我国在网络安全国际标准化组织中的影响力和话语权。**
- 加大标准规范的宣传贯彻力度，推动云计算安全标准应用落地，

云计算专业化、规模化的新计算模式，给云计算业务带来了新的安全挑战，安全问题成为影响云计算发展的关键。未来，为了更好地应对云计算发展的新老安全问题，我国应坚持鼓励支持和规范发展并行，从推进安全标准、健全安全机制等方面，不断推动云计算技术的安全发展和应用。

◆ 加强云计算安全监管力度

- 1 • 落实《网络安全法》重点要求，将重点领域、重点行业云基础设施纳入**关键信息基础设施安全管理范畴**，落实云服务商安全防护主体责任，加大云安全防护监管力度。
- 2 • 研究**健全云服务安全信用管理机制**，统筹运用安全评估、责任考核等监管手段，将公有云服务商安全纳入主管部门安全巡检，将巡检结果作为云服务商信用指标；
- 3 • 持续开展**云计算安全领域的网络安全试点工作**，推动企业加大新兴领域的研发，促进先进技术和经验的推广应用。
- 4 • 强化**风险评估机制**，尤其是云计算在物联网、工业互联网等新业务中威胁分析，保障云计算技术在新业务中的安全应用。



ISC 互联网安全大会



360 互联网安全中心

谢谢!

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing · China

(原“中国互联网安全大会”)